



# IT Applications:

Electronic media in business and commerce

## **Secure communication**

Dariusz Caban  
[dariusz.caban@pwr.edu.pl](mailto:dariusz.caban@pwr.edu.pl)





# Certificate

- How to prevent spoofing with the public key?
- A simple solution
  - A trusted third-party (Certificate Authority CA institution) vouches for the identity of the owner of the public key
  - CA does so by issuing an electronic document which
    - Identifies the owner of the certificate
    - Includes the public key of the owner
    - Specifies when the certificate expires (cannot be used any longer)
    - Specifies the legal applications of a certificate
  - CA signs the certificate using its private key, thus vouching for its authenticity
  - CA includes its certificate to prevent CA spoofing
- CA certificate chain
  - Root CA has a self-signed certificate
  - Self-signed certificate does not prevent spoofing

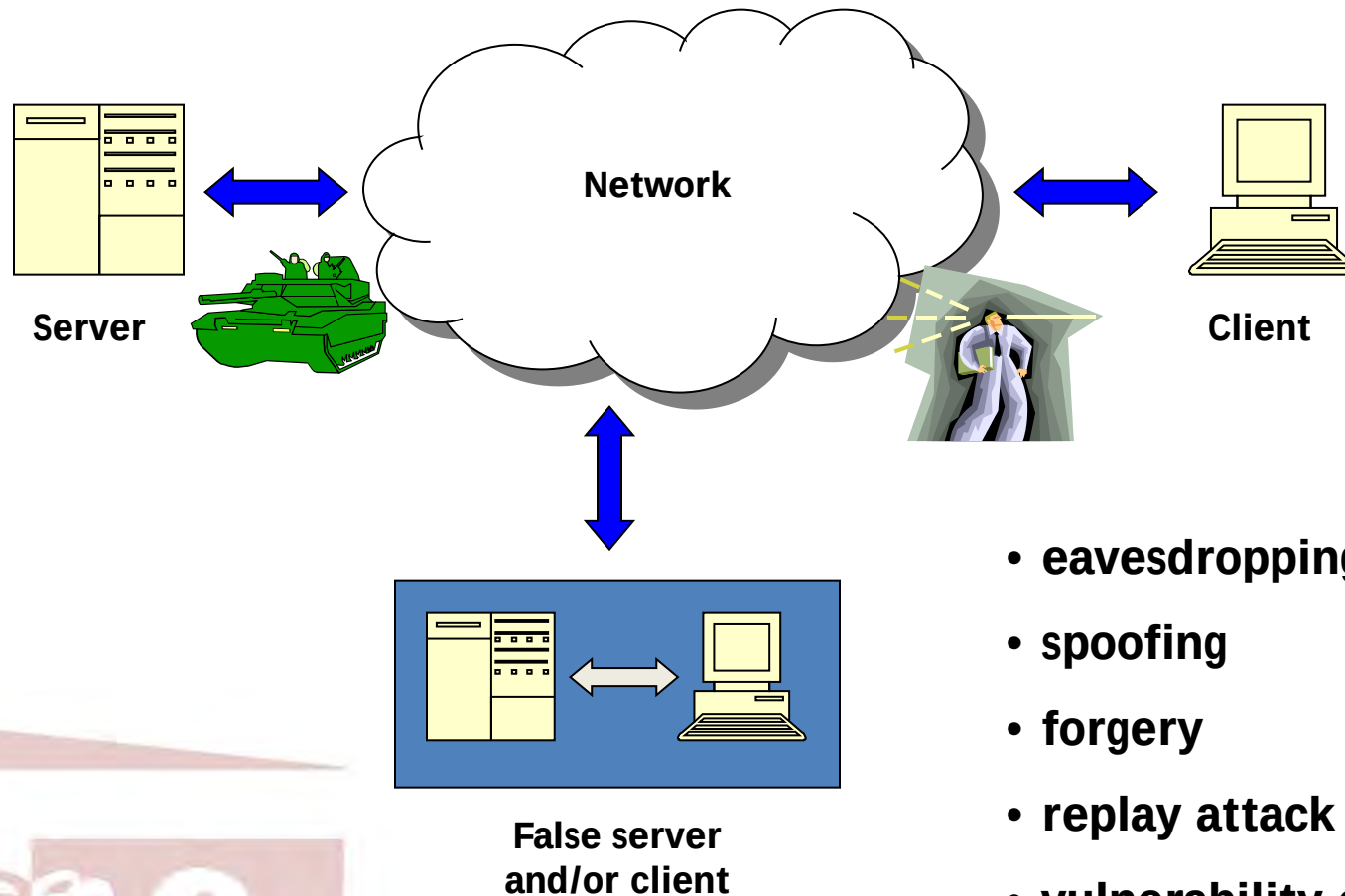




*Secure communication is the basis of all  
electronic business applications*



# Threads



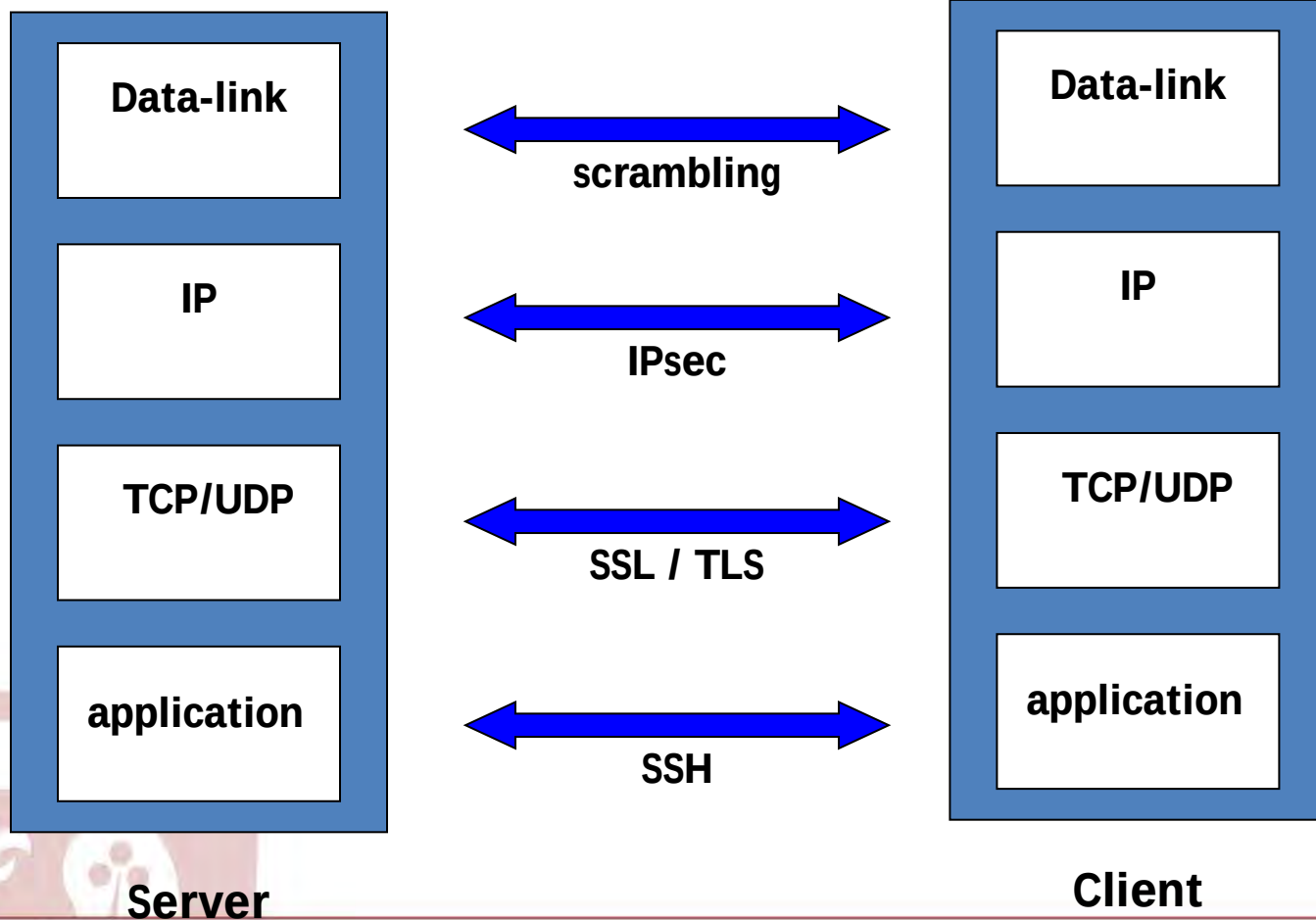
# Aim of communication encryption



- Confidentiality
  - Protection of private data
  - Limiting access to information (to authorized users)
  - Protection of client data – client trust
  - Protection of privacy
- Data integrity
  - Forgery possible only if data is decrypted
  - Modification of encrypted bitstream – broken data
  - Encryption is not sufficient!
- Sender authentication
  - Encryption ensures weak authentication – based on common secret
- Protection against replay attack
  - By means of session keys (encryption is insufficient)



# Protocol layers used in encryption





# SSL and TLS protocols

- Acronyms
  - SSL – **S**ecure **S**ocket **L**ayer
  - TLS – **T**ransport **L**ayer **S**ecurity
- Protocol developed by Netscape Communications Corp.
- Model implementation by RSA Securities
  - RSA owned most of the patents for SSL implementation
- Popular open-source implementations by E. Young (SSLeay) and OpenSSL
- Transport level protocol used in application protocols:
  - https (http messages sent via SSL/TLS link)
  - Pops, imaps (mail protocols used via SSL/TLS links)
  - ...



# Components of SSL communication



- Connection encrypted using a symmetric cipher
  - Alternative ciphers are negotiated
  - Cipher negotiated between client and server
  - Null-encryption can be negotiated
- Connection integrity ensured by MAC or HMAC
- Session key used in encryption and MACs
  - Key is randomly generated
  - Key is exchanged using a public cipher suite
  - Key exchange algorithm (RSA, Diffie-Hoffman) is negotiated between client and server
- Server is authenticated on the basis of its certificate
- Optional compression algorithm
- Uses TCP packets





# ClientHello / ServerHello

- Negotiation of SSL protocol version
- Negotiation of Cipher Suite
  - Session exchange algorithm (RSA, Diffie-Hellman)
  - Symmetric cipher
    - Null encoding
    - RC4 40/128
    - RC2 40
    - AES 128/256
    - 3DES, IDEA, Fortezza
  - MAC generation
    - Null, MD5, SHA1
- Compression
- Negotiation of session key
- Server authentication (optionally client auth.)





# HTTPS

- Messages based on HTTP
- Protocol uses SSL / TLS links
- Client recognizes need for encrypted connection, based on the URL format:  
https://normal\_URL\_format
- Default port for HTTPS communication:
  - Port 80 (default for HTTP) is NOT used
  - Port **443**
  - This allows serving of HTTPS and HTTP messages from the same server
- Combined HTTP and HTTPS page content
  - Reduces server side processing
- Popular implementation Apache / mod\_SSL





# Secure Apache configuration

- SSLEngine on
- SSLCertificateFile and SSLCertificateKeyFile
  - Point to files with server certificate and private key (if separate)
  - Required for server authentication
  - Certificate CN name must be the same as its DNS address
  - Certificate SAN optional field must have its DNS address
  - Optionally, alternative files for RSA and DSA authentication
  - Problem when server has DNS aliases (virtual servers)
- SSLPassPhraseDialog
  - How to decrypt the server private key
- SSLCertificateChainFile
  - CA certification chain of the server





# Client authentication

- SSLVerifyClient
  - none, optional, optional\_no\_ca, **require**
- SSLVerifyDepth
  - Max. length of CA certification chain
  - Should be small, 1 => certificate issued by directly known CA
- SSLCACertificatePath
  - Directory of all recognised CAs
  - A link named as #hash.N obtained from certificate DN
- SSLCARevocationPath
  - Directory of all recognised CAs revocation lists
- User has to provide his certificate to be authenticated
- Certificate may be soft or recorded on a USB key



# Electronic access to bank accounts



- Secure connection with the server using HTTPS
  - Server certificate should prevent spoofing
  - Certificate issued by a trusted CA (eg. VeriSign, Entrust)
  - Server should ensure secure level of encryption
- Access to the server should be authenticated
  - Simple passwords (can be hijacked by software installed on the client computer)
  - Single use passwords
  - Identification tokens and USB keys
- Some operations may require additional authorization
  - PIN sent via an independent channel of communication (SMS to the client mobile phone)
  - Phone authorization





# Bank transfer

- Transfer funds from one account to another
  - Payer initiates transfer from his account, stating the account of the recipient (IBAN)
  - Payer bank sends a message to the recipient bank to remit funds to his account (using secure connection, e.g. SWIFT)
  - The message contains information required for interbank settlements
  - If no interbank settlements agreement, settlement via a correspondent bank
  - In Poland, ELIXIR run by Elektroniczna Izba Rozrachunkowa
- Transaction hazard
  - Relatively safe, authenticated payer and recipient
  - Danger related with anonymous recipient
  - Danger of fraud – transaction is irrevocable
- Smartphone payments

